AEGIS BANK

Vulnerability Management Policy

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Vulnerability Management Policy
Document ID	**AB-CYB-009**
Department	Cybersecurity & Risk Management
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Vulnerability Management Lead
Classification	Restricted
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This policy establishes the processes for identifying, assessing, prioritizing, remediating, and monitoring security vulnerabilities across Aegis Bank's technology environment.

The objective is to reduce cyber risk by ensuring timely remediation of security weaknesses while maintaining operational stability.

Unauthorized distribution of this document is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Vulnerability Management Objectives
4. Roles & Responsibilities
5. Asset Coverage
6. Vulnerability Lifecycle
7. Vulnerability Severity Classification
8. Scanning & Assessment
9. Patch Management
10. Exception Management
11. AI & RAG Platform Security
12. Reporting & Metrics
13. Practical Examples
14. Frequently Asked Questions
15. Revision History
16. Document Approval

---

1. Purpose

The purpose of this policy is to establish a standardized vulnerability management process that protects Aegis Bank against security threats.

Objectives include:

- Identify vulnerabilities.
- Reduce cyber risk.
- Improve system resilience.
- Maintain regulatory compliance.
- Support continuous security improvement.

---

2. Scope

This policy applies to:

- Core Banking Systems
- Web Applications
- APIs
- Cloud Infrastructure
- Databases
- Employee Endpoints
- AI & RAG Platform
- Network Devices

---

3. Vulnerability Management Objectives

Aegis Bank aims to:

- Discover vulnerabilities early.
- Prioritize risks based on business impact.
- Remediate critical issues promptly.
- Continuously monitor the environment.
- Verify successful remediation.

---

4. Roles & Responsibilities

Role	Responsibility
CISO	Executive oversight
Vulnerability Management Team	Coordinate scanning & remediation
IT Operations	Deploy patches
Application Owners	Resolve application vulnerabilities

Role	Responsibility
AI Engineering	Secure AI platform
Risk Management	Track residual risks

---

5. Asset Coverage

The following assets are included:

- Servers
- Workstations
- Mobile devices
- Firewalls
- Routers & Switches
- Databases
- Banking Applications
- AI Models
- Vector Database
- Cloud Services

---

6. Vulnerability Lifecycle

Asset Discovery

↓

Vulnerability Scan

↓

Risk Assessment

↓

Prioritization

↓

Remediation

↓

Validation

↓

Continuous Monitoring

---

7. Vulnerability Severity Classification

Severity	Description	Target Remediation
Critical	Immediate business risk	24 Hours
High	Significant security impact	7 Days
Medium	Moderate risk	30 Days
Low	Minor impact	90 Days

Risk prioritization considers:

- CVSS score.
- Exploit availability.
- Business criticality.
- Data sensitivity.
- Regulatory impact.

---

8. Scanning & Assessment

Scanning activities include:

- Weekly authenticated vulnerability scans.
- Monthly external perimeter scans.
- Quarterly web application security assessments.
- Annual penetration testing.
- Continuous cloud configuration monitoring.

Findings are validated before remediation begins.

---

9. Patch Management

Patch process:

Patch Released

↓

Risk Review

↓

Testing

↓

Approval

↓

Deployment

↓

Verification

Patch priorities:

- Critical security patches.
- Operating system updates.
- Application updates.
- Third-party software fixes.
- Firmware updates.

Emergency patches may bypass the normal release schedule after appropriate approval.

---

10. Exception Management

If remediation cannot be completed within the required timeline:

- Business justification must be documented.
- Risk assessment must be performed.
- Temporary compensating controls must be implemented.

- Executive approval may be required.
- Exception review dates must be defined.

---

11. AI & RAG Platform Security

Security assessments cover:

- LLM APIs
- Prompt injection exposure
- Vector database permissions
- Knowledge base integrity
- Embedding services
- AI configuration

Additional AI controls include:

- Prompt validation.
- Retrieval authorization.
- Output monitoring.
- Model version tracking.

---

12. Reporting & Metrics

Security dashboards track:

Metric	Purpose
Open Critical Vulnerabilities	Immediate risk visibility
Patch Compliance Rate	Measure update effectiveness
Mean Time to Remediate (MTTR)	Measure response efficiency
Scan Coverage	Ensure asset visibility
Exception Count	Monitor accepted risks

Reports are reviewed monthly by Cybersecurity and Executive Management.

---

13. Practical Examples

Example 1 — Critical Server Vulnerability

1. Weekly scan detects a critical vulnerability.
2. Security team validates the finding.
3. Emergency patch approved.
4. Patch deployed within 24 hours.
5. Follow-up scan confirms remediation.

Example 2 — Banking Application Vulnerability

1. Security assessment identifies an API weakness.
2. Development team implements a fix.
3. Security testing validates the update.
4. Application is redeployed.

Example 3 — AI Platform Assessment

1. Prompt injection testing is performed.
2. Weak filtering rules are identified.
3. Prompt validation is strengthened.
4. AI service is retested before release.

---

14. Frequently Asked Questions (FAQs)

Q1. Why is vulnerability management important?

It reduces security risks before attackers can exploit them.

Q2. How often are vulnerability scans performed?

Scanning frequency depends on asset type, with critical systems scanned at least weekly.

Q3. Are AI systems included?

Yes. AI models, vector databases, APIs, and retrieval services are part of the assessment scope.

Q4. How are critical vulnerabilities prioritized?

Based on severity, exploitability, business impact, and regulatory risk.

Q5. What happens if a vulnerability cannot be fixed immediately?

A formal risk exception process with compensating controls is required.

---

15. Revision History

Version	Date	Description	Author
v1.0	May 30, 2026	Initial Vulnerability Management Policy	Cybersecurity Team
v1.1	June 18, 2026	Added AI Platform Security Assessment	Security Engineering
v1.2	**July 24, 2026**	**Enhanced Risk Prioritization, Patch Management, AI Security Controls, and Enterprise Metrics**	**Cybersecurity Department**

---

16. Document Approval

Field	Details
Document ID	**AB-CYB-009**
Document Title	**Vulnerability Management Policy**

Field	Details
Department	Cybersecurity & Risk Management
Version	**v1.2**
Classification	**Restricted**
Document Owner	Vulnerability Management Lead
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Cybersecurity, IT Operations, AI Engineering, Risk Management
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Vulnerability Management Policy v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.
